



ISC 互联网安全大会



360 互联网安全中心



数字身份的最佳实践——以人为核心的业务安全

孙悦 芯盾时代联合创始人 首席技术官

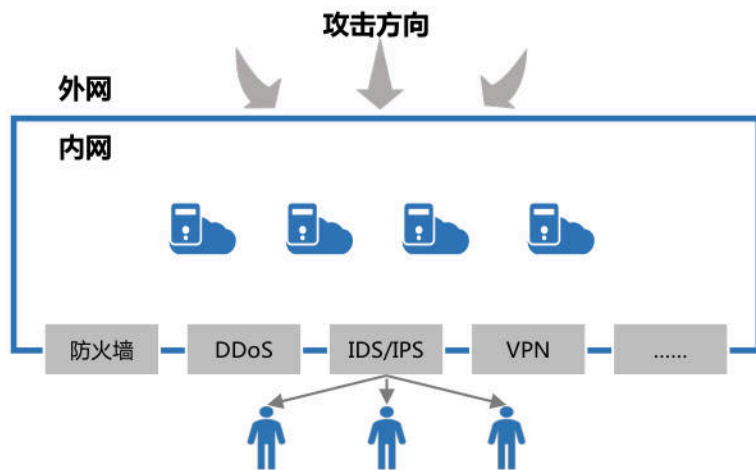
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

业务安全正当时，身份重构安全边界，零信任模型成为主流

- 统计显示，2017年重大数据泄露事件中**被盗身份是主要突破口**，**81%**的相关安全事件都源于被盗、默认或弱口令
- 新的安全形势下必须以身份为新的安全边界，“**零信任模型**”将成为最优选择

传统安全

- 背景：信息单向流动，网络核心价值点是设备
- 方式：通过防火墙/DDoS/IDS/IPS等安全设备构建防御边界



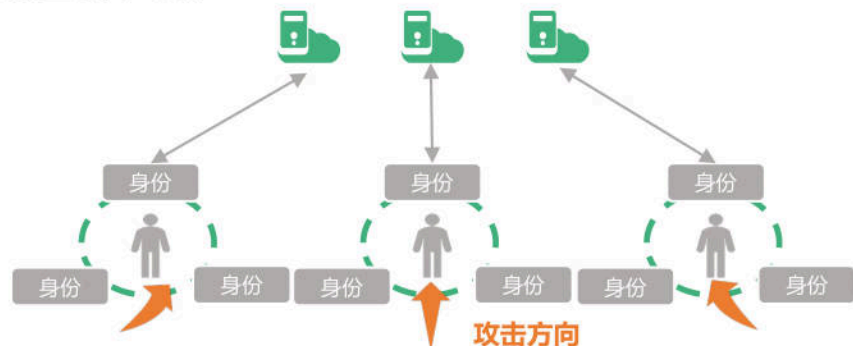
传统安全模型认为内网环境是可信任的，内网内部安全防护薄弱；一旦攻破网络边界，整个体系就会处于高度威胁之中

业务安全

- 背景：移动互联网信息多维流动，“人”是网络核心价值点
- 方式：传统边界消失，以身份为新边界，构建“零信任模型”

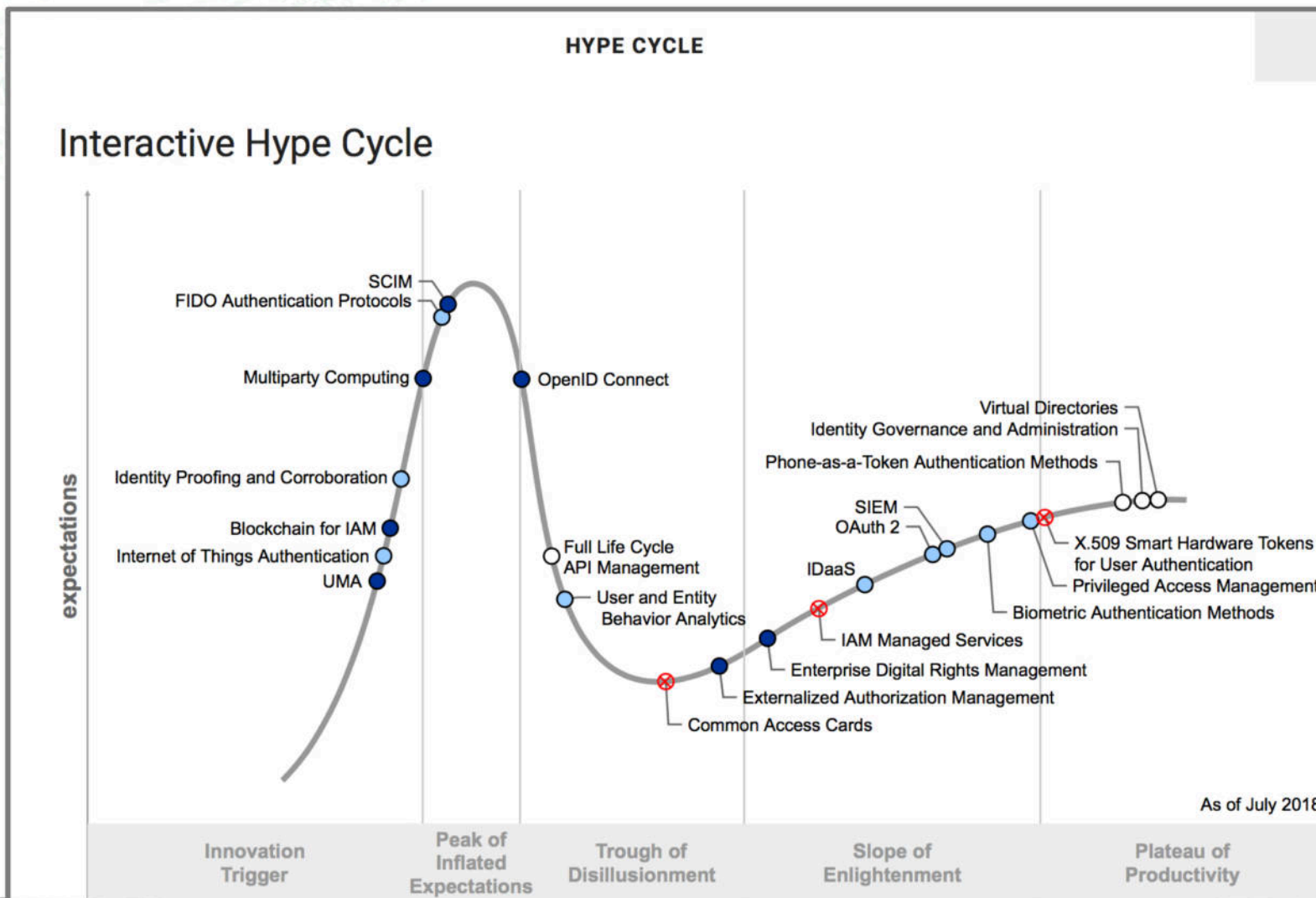
传统网络边界消失

身份重构安全边界



只要处于网络中，任何用户都不可被信任。在零信任模型下，任何时刻任何环节，设备、身份及权限都有必要被验证

技术驱动-技术成熟度曲线

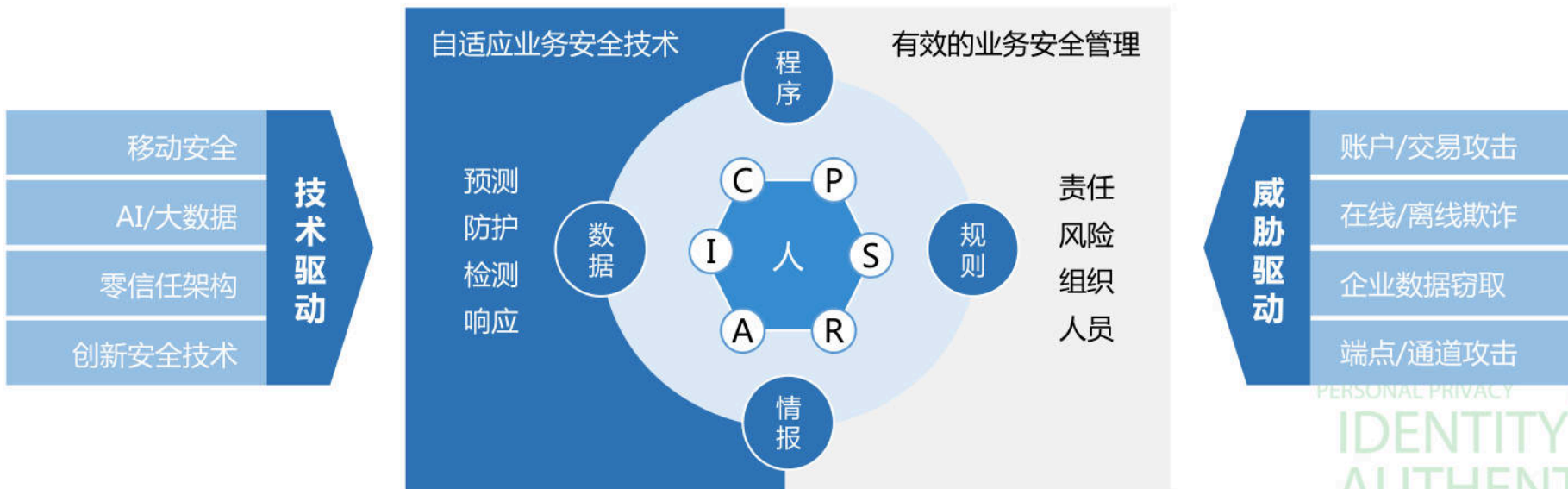


各行业业务安全基础薄弱，三大因素共同推动业务安全体系落地



业务即安全
安全即业务

- 业务需求：增加收入、节省开支、降低成本、提高效率、提升形象、监管合规
- 行业现状：业务安全基础薄弱、技术落后，效率低下、管理复杂，威胁感知慢



ZERO TRUST SECURITY

C—Confidentiality ; I—Integrity ; A—Availability; P—Privacy ; S—Safety ; R—Reliability ;

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

- 正面识别信号
- 混合识别信号
- 负面识别信号



认证行为分析、应用行为分析等

用户在监测时间内的行为特征，包含点击次数、停留时间等

IDENTITY AUTHENTICATION

ISC 互联网安全大会 中国·北京

Internet Security Conference 2018 Beijing · China

芯盾时代：提供场景化身份认证和业务安全服务



ISC 互联网安全大会



360 互联网安全中心

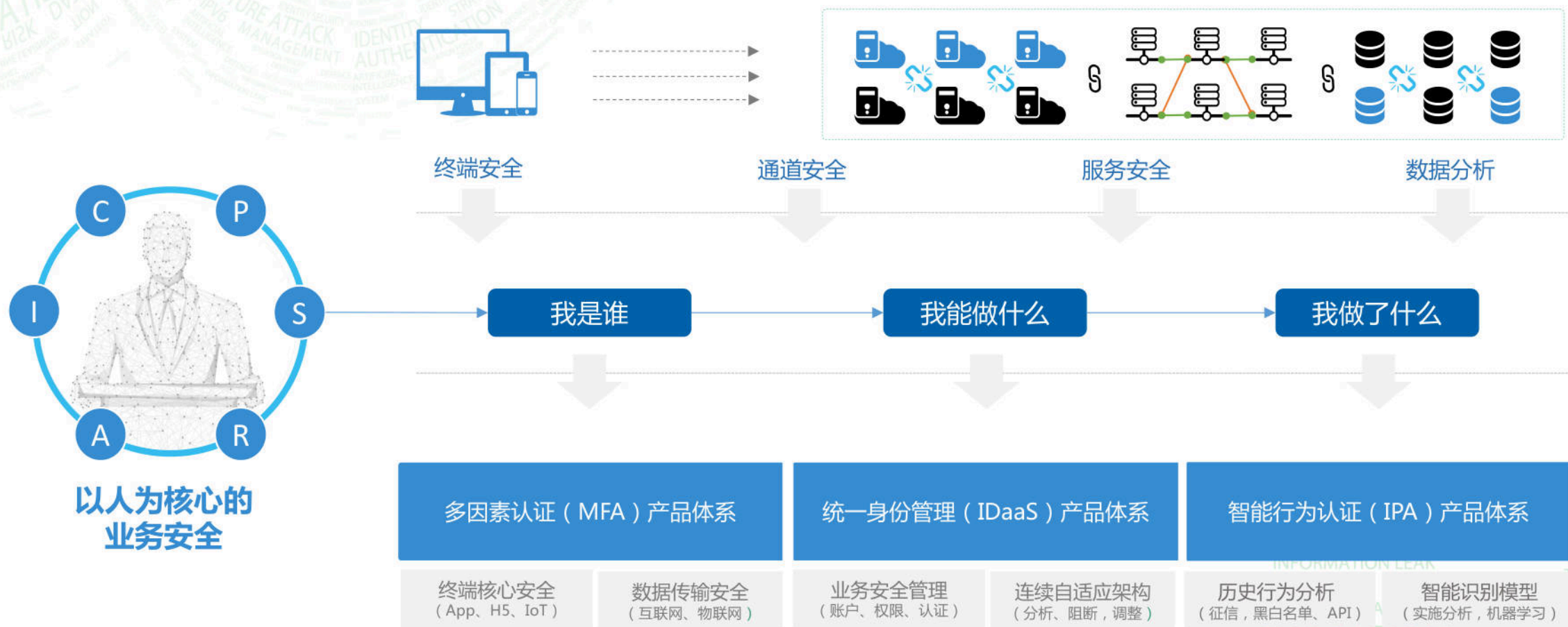
- 以人为核心，用创新科技赋能安全领域，成为国际领先的“身份认证和业务安全”产品服务提供商

场景	金融	政府	运营商	互联网	其他
产品	多因素认证（MFA）产品体系		统一身份管理（IDaaS）产品体系		智能行为认证（IPA）产品体系
模型	终端数据安全模型	信息传输安全模型	风险识别策略模型	智能分析策略模型	
技术	底层安全		大数据&AI	身份认证	
理念	零信任模型：网络环境中所有用户都不可信任，需对用户、设备、访问及权限进行连续判断（IP风险，密码风险，账号风险，设备风险，行为风险，历史信誉风险）				

ZERO TRUST SECURITY

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

全流程身份认证和业务安全矩阵



ZERO TRUST SECURITY

多因素认证 (MFA)

1. Knowledge

Passwords and PINs, images, patterns and so on.

3. Biometric Traits

Biological and behavioral characteristics.



2. Tokens

Smart cards and USB tokens, OTP hardware tokens, phone-as-a-token methods.

统一身份管理 (IDaaS)

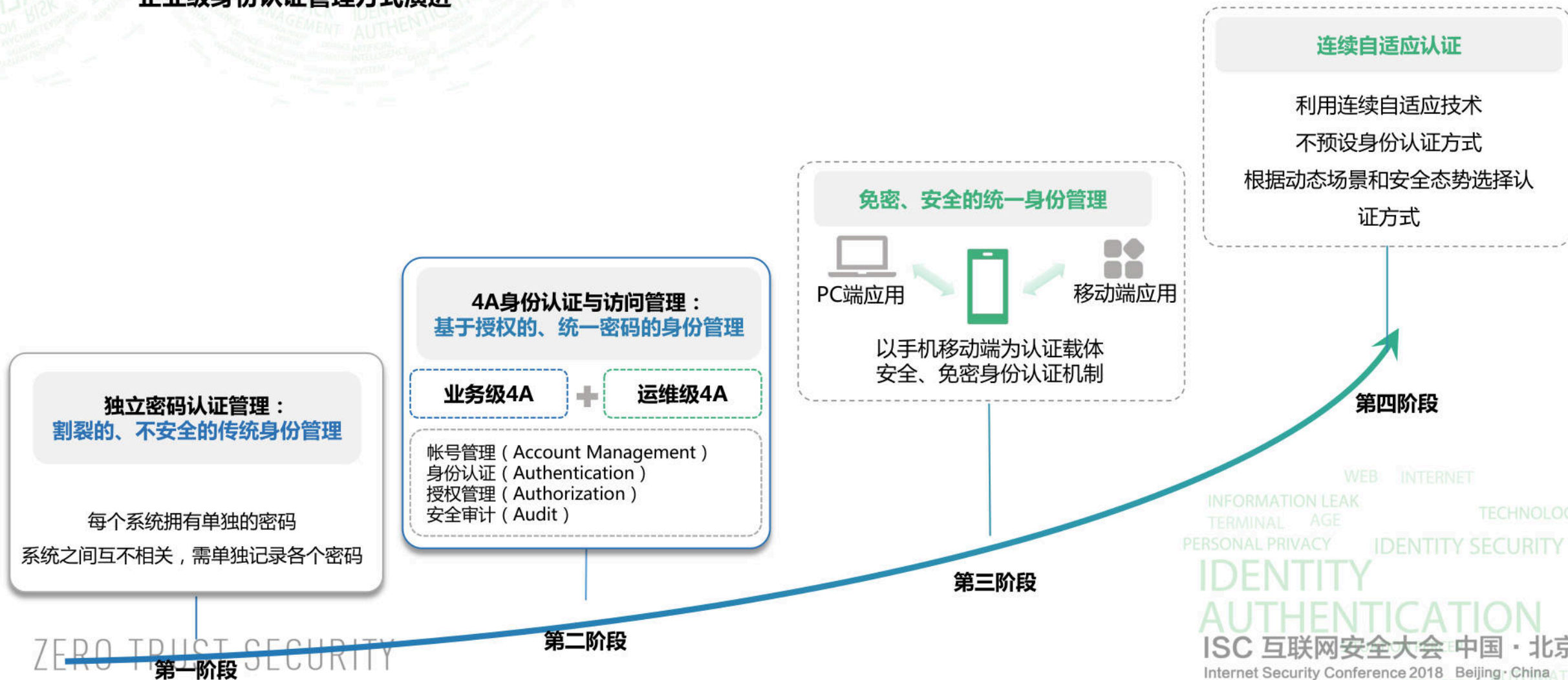


ISC 互联网安全大会



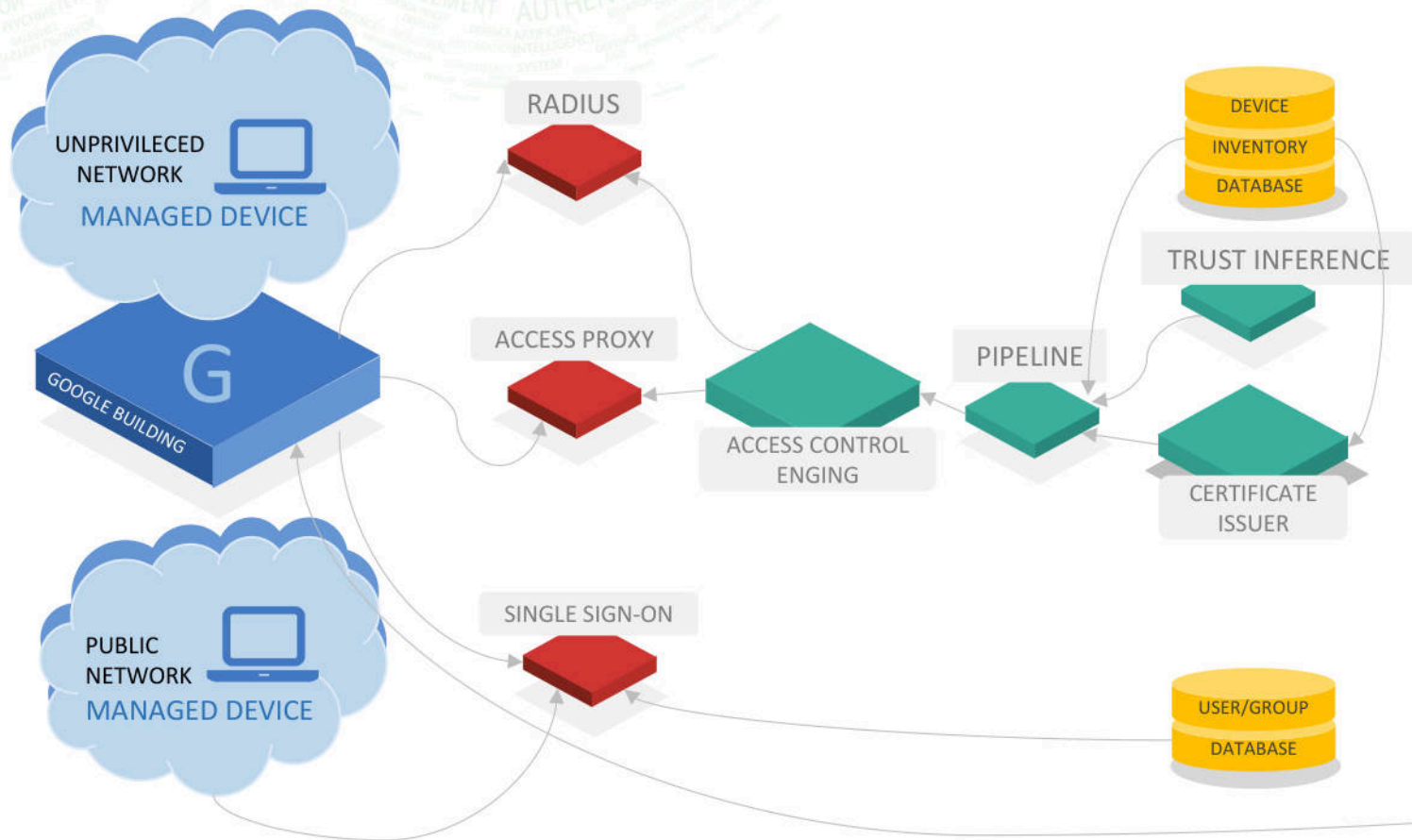
360 互联网安全中心

企业级身份认证管理方式演进



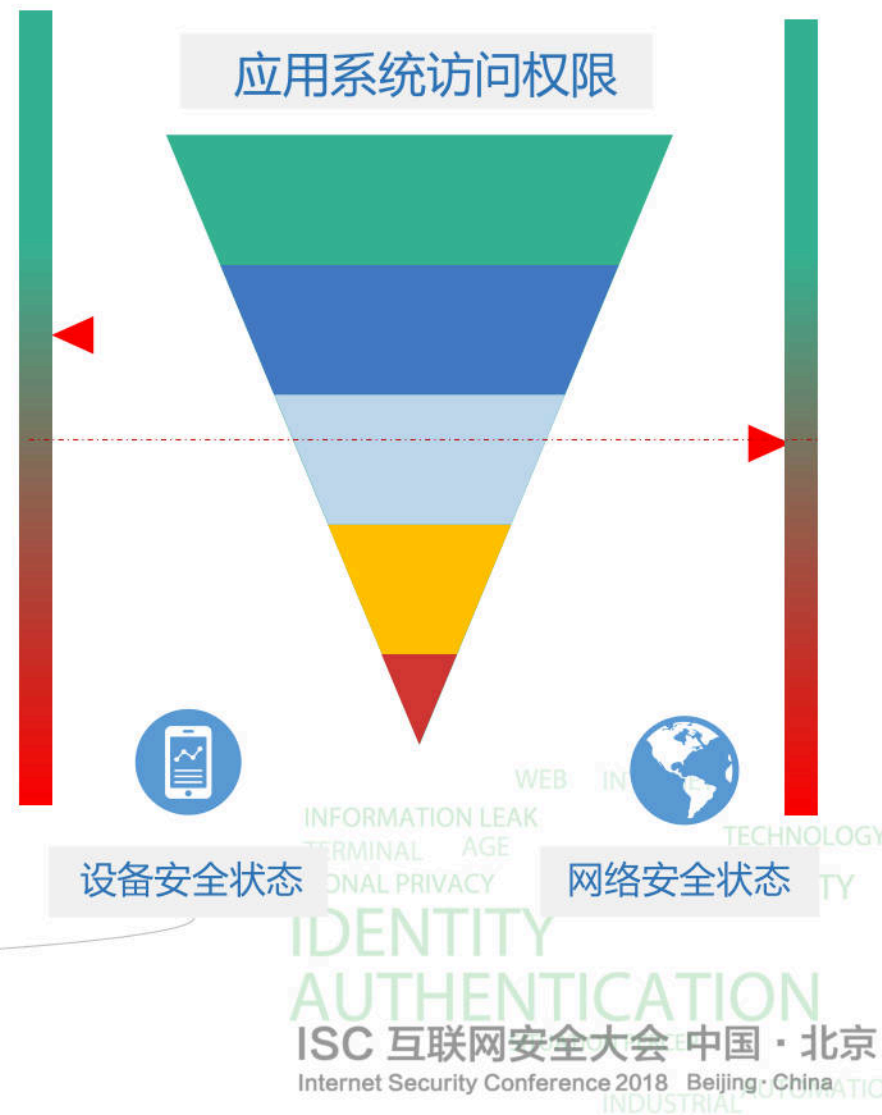
谷歌零信任安全架构

BEYONDCORP A NEW APPROACH TO ENTERPRISE SECURITY

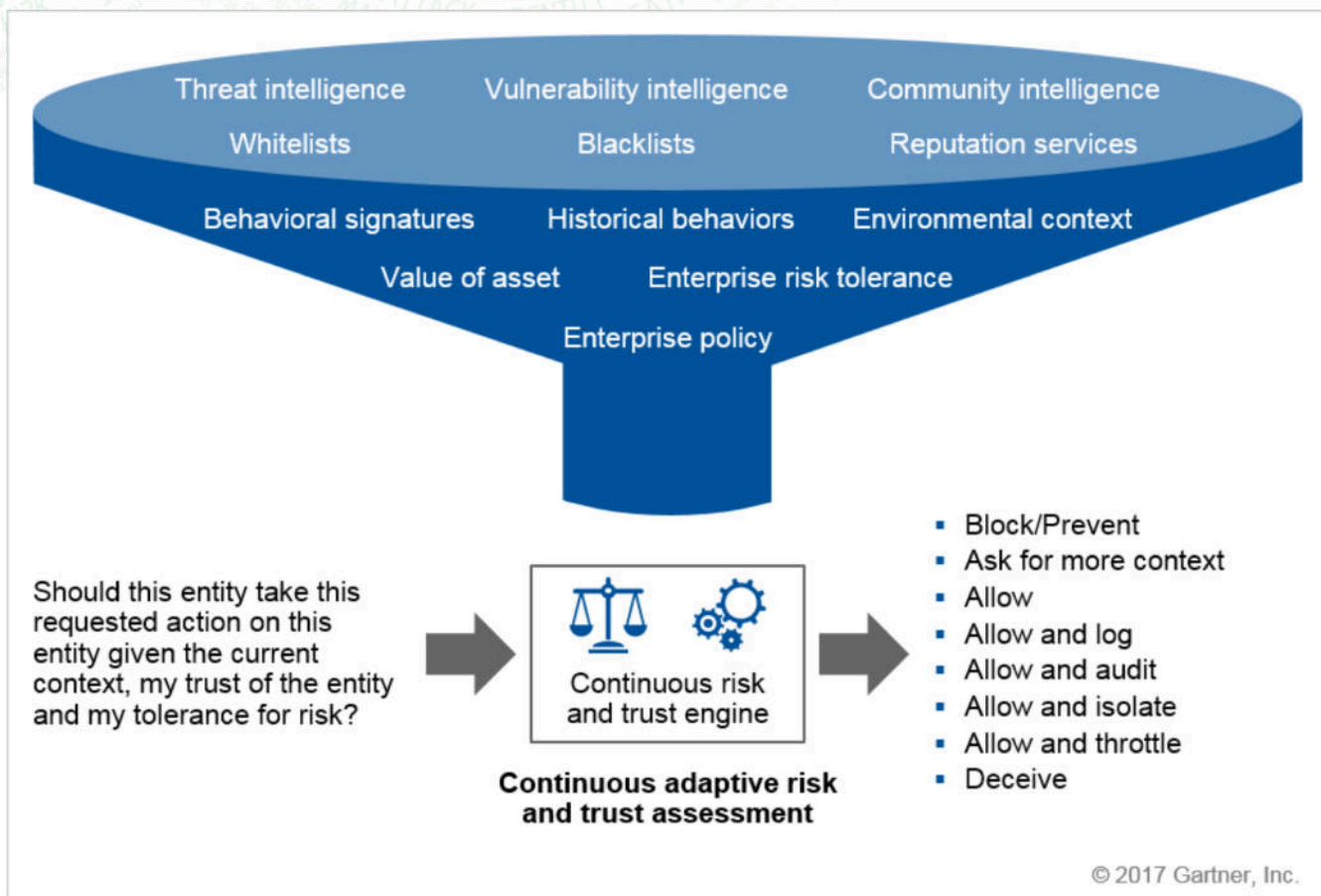


BeyondCorp components and access flow

ZERO TRUST SECURITY



连续自适应认证



CARTA:
continuous adaptive risk and trust
assessment



ZERO TRUST SECURITY

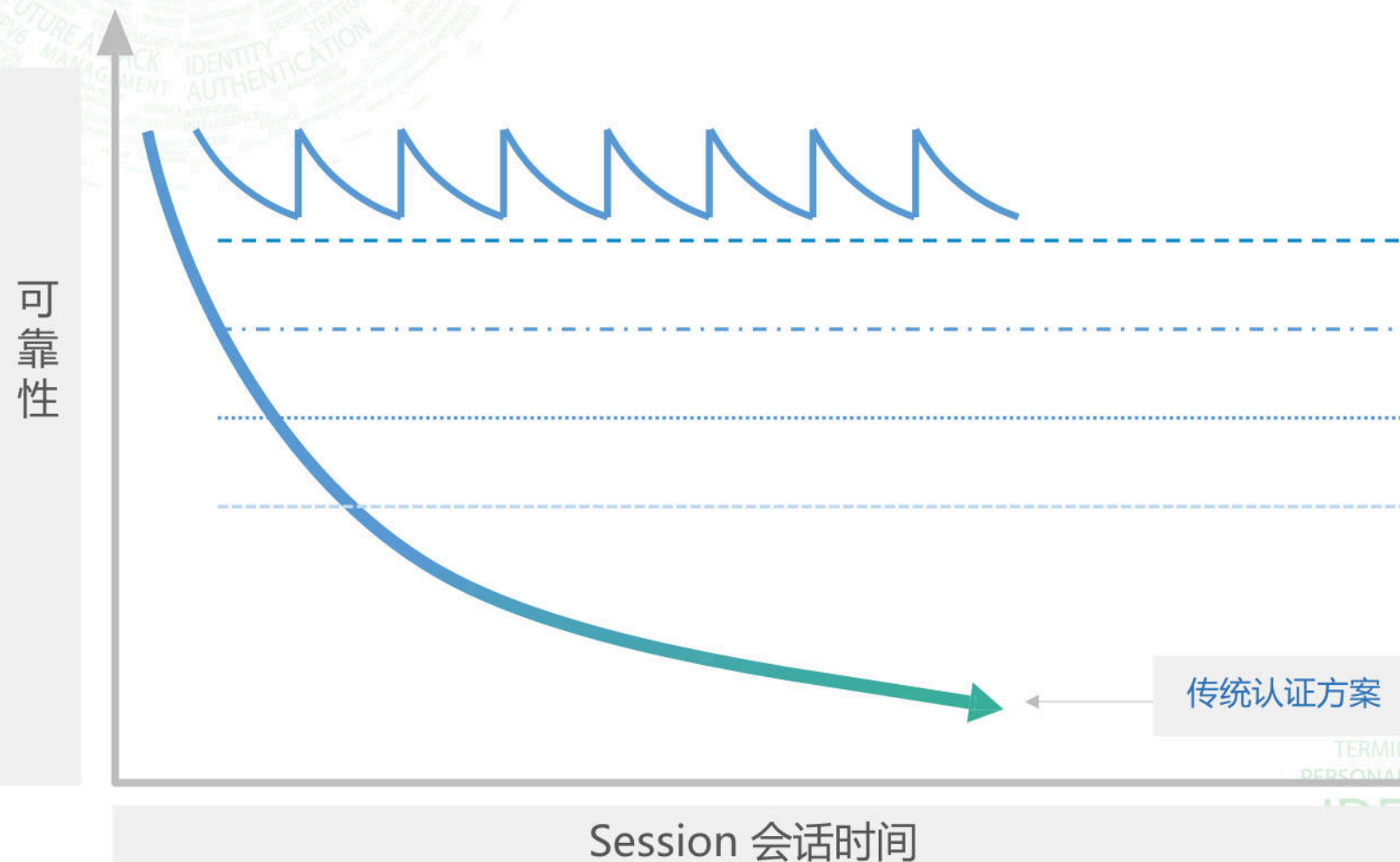
连续自适应认证



ISC 互联网安全大会



360 互联网安全中心



ZERO TRUST SECURITY

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing · China

数据源与机器学习



ISC 互联网安全大会



360 互联网安全中心



人



设备



应用

终端信息源

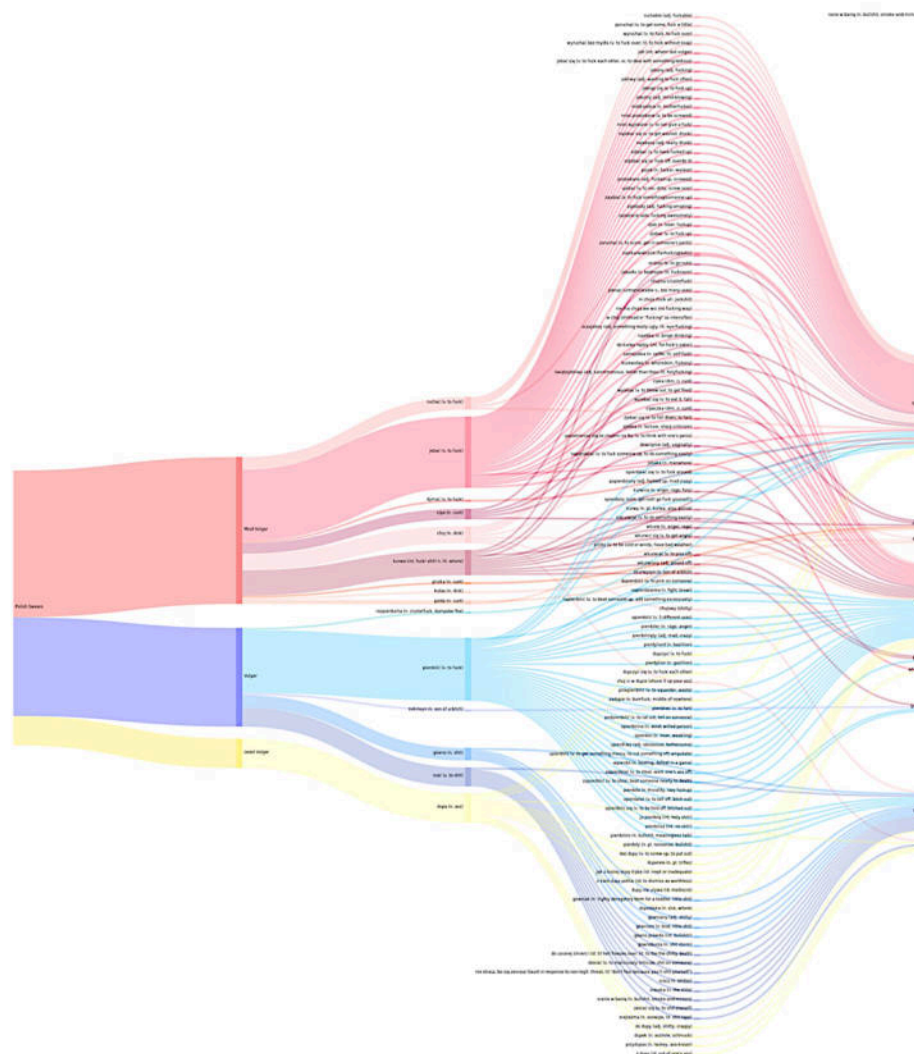
- Mobile设备信息
- PC 设备信息
- 浏览器信息
- 终端安全(木马/病毒)
- 环境安全(模拟器/调试)
- 位置信息(位置改变)
- 操作习惯(时间/频率)
- 常在习惯
- 操作信息(登录成功/失败)
-

网络信息源

- 防火墙
- WAF
- 堡垒机
- IDS/IPS
- 上网行为管理
- VPN
- Wifi
- VMWARE
- Docker
-

应用信息源

- 登入/登出
- 访问轨迹
- 访问频率(停留时间)
- 访问内容(重要度)
- 数据量统计
- 数据库访问
- 导入导出
- 用户信息/数据详情
- 管理员行为审计
-



ZERO TRUST SECURITY

AUTHENTICATION
ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing·China

智能行为认证 (IPA)

- 基于海量多源异构行为数据和和**亿万量级**精准欺诈数据，结合机器学习算法，形成了一整套由**上千组**规则因素、无监督学习引擎组成的智能实时身份反欺诈系统，在零信任模型下，不预设身份认证方式，根据实时安全环境确定认证方式，实现正常用户的无感知身份认证和欺诈用户精准识别

反欺诈平台：灵活、高效的引擎及管理

- 高性能规则引擎
- 分布式实时引擎
- 可视化管理能力
- 欺诈图谱检测

多算法支持：与数据特点结合的机器学习算法

- 有监督学习
- 半监督学习
- 无监督学习
- 迁移学习
- 增强学习

信用评分
模型

用户画像
模型

新规则
挖掘模型

反欺诈模型

欺诈样本
标注模型

阈值/权重
动态调整
模型

多模态引擎：多引擎应对不同阶段、目标

- 机器学习引擎
- 图计算引擎
- 离线计算引擎
- 深度学习引擎
- 数据探索引擎
- 流式特征引擎
- 可视化建模引擎

海量数据：结合内外部数据进行辅助决策

针对不同情景采用不同规则、算法，实现无感知认证和反欺诈



交易欺诈



羊毛党



游戏行业欺诈



团伙欺诈



企业信息泄露



信贷欺诈



运营商



合作客户



大数据联盟



互联网企业

ZERO TRUST SECURITY



ISC 互联网安全大会



360互联网安全中心

谢谢！

ISC 互联网安全大会 中国·北京
Internet Security Conference 2018 Beijing · China